

Technical Data Protection Documentation

Small Internal Domain Scraper
Prepared for privacy and data security review
Version date: 2026-07-17

This document describes the intended local data flow, technical controls, assumptions, residual risks, and open review questions for the local browser scraper. It is technical documentation and does not replace legal assessment, works council review, or formal controller approval.

1. Scope And Purpose

The tool extracts a narrow set of values from an internal web application into a local XLSX or CSV file. The currently configured Wesser use case reads a local Excel input list containing an identifier, searches the internal website for each record, extracts only the configured percentage values, and writes a minimal result file.

- Configured source page: <https://my.wesser.de/FundraiserList>
- Accepted input identifier headers: PseudoID, Fundraiser Number, FundraiserNumber, Fundraiser-Number, MA-Nummer, MA Nummer.
- Configured extracted fields: Individuelle StRL% and Individuelle Vorschuss%.
- Output format: local XLSX or CSV, plus an optional local checkpoint file for resume capability.
- Primary design goal: local-only processing with minimal extraction and no transfer of input, output, screenshots, full page text, HTML, cookies, or session data to third-party services by this tool.

2. Assumptions From Privacy Documentation

- The operating company is the responsible party for approving purpose, legal basis, access rights, retention period, and operational process.
- The user running the scraper is authorised to view every queried record in the internal source system.
- The input list contains only identifiers required for the approved extraction purpose.
- Where feasible, the preferred input header is PseudoID, but PseudoID and Fundraiser Number must both be treated as personal data unless the company confirms true anonymisation.
- The output location is local or company-controlled and protected by appropriate access controls.
- The browser profile, input files, output files, and checkpoint files are protected and deleted or archived according to internal retention rules.
- Internal website scraping is permitted by company policy and by the owner of the source system.
- Works council, HR, or employee-monitoring requirements are checked where applicable.
- Internal website access logs or audit logs may be created outside this project and remain subject to company review.
- This project does not guarantee GDPR compliance by itself; it provides a privacy-conscious technical baseline that must be embedded in a compliant company process.

3. Data Flow

Step	Component	Data processed	Storage or transfer
1	Local input XLSX	Identifier column only, preferably PseudoID or approved Fundraiser Number.	Stored locally or in approved company location before execution.
2	Local Python process	Reads identifiers, validates numeric IDs, removes duplicates, controls browser automation.	Process memory only, except checkpoint/output files.
3	Local browser profile/session	Authenticated session and rendered internal record pages.	Stored in local profile directory; may contain session-sensitive browser state.
4	Internal website	Search by identifier and display of source record.	Internal system may create normal access/audit logs.
5	Parser	Extracts only configured labels: Individuelle StRL% and Individuelle Vorschuss%.	No intentional full-text, HTML, screenshot, cookie, or storage dumps.
6	Local output XLSX/CSV	Identifier plus configured extracted values.	Written locally; must be moved/protected/deleted under company policy.
7	Optional checkpoint	Per-record progress and extracted configured values for resume.	Written locally beside output; ignored by Git; delete when no longer required.

Textual flow: Local input XLSX -> local Python process -> local browser profile/session -> internal website search/detail page -> local parser extracts configured fields only -> local output XLSX/CSV and optional local checkpoint.

4. Data Categories And Explicit Non-Goals

Category	Included / excluded	Notes
Expected input	PseudoID or Fundraiser Number / MA number.	Identifiers are personal or pseudonymous data if the company can map them to an individual.
Expected output	Same identifier column plus Individuelle StRL% and Individuelle Vorschuss%.	Empty source values remain empty; percent values are normalised by scraper logic.
Not intentionally written	Names, private addresses, email addresses, phone numbers, birth dates, tax IDs, bank details, full page text, HTML dumps, screenshots, cookies, session tokens.	Developers must not add broad logging or debug dumps without privacy review.

5. Technical Measures

- Local-only execution: the scraper reads local files, drives a local browser, and writes local files. The scraper code does not intentionally send data to OpenAI, GitHub, hosted scraping infrastructure, or other third parties.
- Configurable minimal extraction: site-specific selectors and field labels live in config/sites/*.json. The core code writes only configured output columns.
- Pseudonymous input support: PseudoID is supported as preferred header where feasible, reducing direct identity data exposure inside the tool.
- Input reduction: the reader accepts numeric IDs, skips invalid rows, and de-duplicates identifiers before scraping.
- No debug dumps by default: no intentional document.body.innerText dumps, page HTML dumps, screenshots, or logs containing record data.

- Git ignore rules: virtual environments, browser profiles, XLSX/XLS/CSV files, checkpoints, and Excel lock files are excluded from normal commits.
- Checkpoint compatibility: checkpoints include version, site name, and field keys; incompatible checkpoints are ignored after material configuration changes.
- Browser profile isolation: automation uses a dedicated local browser profile directory by default, separated from the user's normal browser profile.

6. Required Organisational Measures

- 1 Document and approve processing purpose, legal basis, scope, and retention period before production use.
- 2 Confirm that the operator's source-system account has a legitimate need and sufficient role-based authorisation for all queried records.
- 3 Store input, output, checkpoint, and browser profile only in approved local or company-controlled locations.
- 4 Define deletion or archiving rules for input, output, checkpoint, and browser profile data.
- 5 Confirm that scraping/automation is permitted by internal IT policy and by the source-system owner.
- 6 Review works council, HR, and employee-monitoring implications where applicable.
- 7 Review source-system audit logs for proportionality and retention.
- 8 Require privacy/security review for any code change that broadens extraction scope, logging, storage, or browser behaviour.

7. Residual Risks

- PseudoID or Fundraiser Number remains personal data where mapping to an employee or fundraiser is possible.
- The local browser temporarily renders full record pages even though the scraper writes only configured fields.
- The internal website may log searched or opened records.
- Browser profile directories may contain session state and must be protected.
- Output files and checkpoints still contain personal or pseudonymous data.
- A future developer could weaken controls by adding broad logging, screenshots, HTML dumps, or forced commits of ignored files.
- This design does not provide encryption at rest, secure deletion, legal-basis validation, works council approval, or source-system permission by itself.

8. Open Question For Improvement

Question for privacy/security review: Should the project add optional pseudonymisation with a local company-controlled key for intermediate files and checkpoints, while still allowing authorised re-identification or final Fundraiser Number output only where required?

Assessment context: local-key pseudonymisation can reduce exposure in intermediate files, logs, checkpoints, and developer troubleshooting. It does not anonymise the data if the company can reverse the mapping, and it does not remove GDPR obligations. If the final business output must contain Fundraiser Number, the main compliance benefit is limited to reducing accidental exposure during processing, not changing the legal nature of the final dataset.

- Decide whether checkpoints should store only pseudonymous IDs, encrypted identifiers, or no identifiers after successful completion.
- Decide who may hold the local key and how key rotation, backup, and deletion should work.
- Decide whether final output should include Fundraiser Number, PseudoID, or both, based on the approved business purpose.
- Decide whether local disk encryption and approved storage paths are mandatory before production runs.

9. Operational Checklist

Before running

- Use an input file with only PseudoID where feasible.
- Do not include names, email addresses, addresses, or additional performance data in the input file.
- Store input and output in an approved local or company-controlled location.
- Confirm the operator is authorised for all records in scope.
- Confirm .gitignore blocks generated data and browser/session artifacts.

During running

- Run locally.
- Do not paste record data into chat tools or external support systems.
- Do not enable debug logging of full page text.
- Do not take screenshots unless separately approved.
- Use visible/non-headless mode only as needed for validation; apply the same privacy controls either way.

After running

- Validate that output contains only expected columns.
- Delete checkpoint files when resume is no longer required.
- Delete or protect the browser profile according to internal policy.
- Move output to the approved storage location.
- Delete local copies when no longer needed.
- Do not commit generated files.

10. Developer Privacy Review Questions

- Does this change add a new data field?
- Does this change broaden page access?
- Does this change write more data to disk?
- Does this change introduce logs, screenshots, HTML dumps, cookies, or browser storage exports?
- Does this change affect checkpoint content?
- Does this change affect where output files are stored?
- Does .gitignore still block generated data?

- Does the change require privacy/security review before production use?

11. References

- GDPR Article 5: principles including purpose limitation, data minimisation, storage limitation, integrity, and confidentiality.
- GDPR Article 25: data protection by design and by default, including appropriate technical and organisational measures.
- GDPR Article 32: security of processing, including confidentiality, integrity, availability, and regular assessment.
- European Commission guidance on data protection by design and by default: processing only necessary data, limiting retention, and limiting accessibility.